

SUPER ADMIN CRM AUDIT REPORT

Date: 2026-07-29

Scope: Super Admin access only

Modules audited: Dashboard, Notifications, Organizations, Billing, Announcements, Audit Log, Profile, Settings, Help

Audit method: Static code and architecture review of frontend, backend, Prisma schema, route guards, API scoping, validation, and UI flows.

Note: No application code or functionality was modified for this audit. This report is the only project artifact created.

EXECUTIVE SUMMARY

The Super Admin area has a strong foundation: role guards exist on the frontend, backend permissions generally centralize access, tenant users are pinned to their own organization, suspended organizations are blocked at authentication time, and billing, announcements, and audit log logic contain several good defensive decisions.

The main risk is not a missing Super Admin role check. The main risk is context leakage: Super Admin can scope into a tenant by setting 'selectedOrganizationId', and the API interceptor then sends 'x-organization-id' automatically. One organization detail/edit route sets this selected organization but does not clean it up, so later global Super Admin pages can behave as if they are still inside that tenant.

The second major risk is server-side tenant route strictness. The frontend prevents many unsafe calls, but shared tenant APIs should still reject Super Admin requests without an explicit organization scope. At least the users API can return a platform-wide user list to a Super Admin if called without a selected organization.

Top priorities:

Priority | Severity | Issue | Main affected area

P0 | High | Stale 'selectedOrganizationId' leaks tenant context into later Super Admin requests | Organization detail, billing banner, feature gates, tenant modules

P0 | High | Public unauthenticated organization slug lookup reveals organization id/status/prefix | Organizations, Super Admin workspace lookup

P0 | High | Shared tenant APIs can be called by Super Admin without explicit tenant scope | Users and other tenant data routes

P1 | Medium | Dashboard KPI semantics are unclear and may include archived/suspended data | Super Admin dashboard

P1 | Medium | Upload middleware can leave orphan files on validation failure | Profile, organization assets

P1 | Medium | Settings page is tenant billing oriented, not platform settings oriented | Settings, billing

P1 | Medium | Announcement scheduled audience is locked by backend but not by UI | Announcements

P2 | Medium | Billing effective-status filtering paginates in memory | Billing console

P2 | Low | Notifications "mark all read" only clears one bounded batch | Notifications

CROSS-CUTTING ARCHITECTURE FINDINGS

Role and Permission Control

Observed:

- Frontend route guards restrict Super Admin-only routes through 'ORGANIZATION_ADMIN_ROUTE_ROLES'.
- Backend 'allowPermission' lets Super Admin bypass permission checks.
- Dashboard route also checks the exact role for each dashboard endpoint.
- Announcement and audit services enforce organization scoping for non-Super Admin users.

Issues:

- UI guards are stronger than some API invariants. For example, Super Admin user list calls are disabled until an organization is selected, but the backend can still return users across organizations if the route is called directly without 'x-organization-id'.

Best-practice solution:

- Treat Super Admin tenant access as two different modes:
 1. Platform mode: only platform endpoints can run unscoped.
 2. Tenant impersonation/scope mode: tenant-data endpoints require a valid organization id.
- Add a backend middleware such as 'requireScopedOrganizationForSuperAdmin' for tenant modules.
- Keep frontend guards as UX protection, but enforce the data boundary in services/middleware.

Organization Data Isolation

Observed:

- Non-Super Admin users are pinned to 'req.organizationId' in 'requireOrganization'.
- Super Admin can optionally scope via 'x-organization-id'.
- Most tenant hooks include selected org id in query keys.

Issues:

- The API interceptor sends 'x-organization-id' for every Super Admin request once selected org exists.
- 'OrganizationDetail' sets selected organization context without cleanup.
- Public slug lookup returns organization id/status/prefix.

Best-practice solution:

- Centralize selected organization context in the Super Admin workspace layout only.
- Clear context on every exit from scoped routes.
- Restrict automatic 'x-organization-id' injection to known tenant endpoint prefixes.
- Require auth for organization slug lookup or return only truly public fields.

Suspended Organization Handling

Observed:

- 'requireAuth' rejects users whose organization status is not 'ACTIVE'.
- Archiving an organization sets 'deletedAt' and forces status to 'SUSPENDED'.
- Super Admin remains able to manage suspended/archived organizations.

Issues:

- Dashboard statistics and some global counts do not clearly state whether suspended or archived organizations are included.
- Help/support copy should clearly explain suspension vs archive behavior.

Best-practice solution:

- Define platform KPI semantics: live active only, active plus suspended, or all-time including archived.
- Add labels/toggles for "Active", "Suspended", "Archived", and "All".
- Ensure every suspend/archive/restore action has an audit row and clear UI confirmation.

Security Posture

Observed:

- Helmet is enabled but CSP is disabled.
- CSRF middleware requires 'x-requested-with' or 'x-csrf-token' for writes.
- Uploads are file-size and MIME/extension checked.
- Uploaded assets are served publicly from '/uploads'.

Issues:

- Header-only CSRF protection is weaker than token-based CSRF.
- Public uploads may expose profile images, organization logos, QR codes, and signatures by URL.

- Uploads can be written before validation fails, creating orphan files.

Best-practice solution:

- Use a real CSRF token or SameSite strategy aligned with production deployment.
- Add CSP, at least in report-only mode first.
- Move uploads through a temp folder and promote only after validation and DB success.
- Delete replaced files or run an orphan cleanup job.
- Consider private object storage or signed URLs for sensitive assets.

MODULE-WISE AUDIT REPORT

1. DASHBOARD

Severity: Medium

Affected functionality:

- Super Admin dashboard KPI accuracy
- Organization lead distribution
- Lead trend charts
- Recent organizations
- Organization status chart

Bugs/issues found:

- Total organizations use 'prisma.organization.count()' without 'deletedAt' filtering, while organization list excludes archived by default. This can make dashboard totals disagree with the Organizations module.
- Organization status grouping does not clearly separate archived organizations from suspended live organizations.
- "Total Revenue" is actually approved quotation value, not subscription or billing revenue.
- Org-wise lead distribution maps every organization then slices top 6 in the UI, without an "Other" bucket.
- Dashboard query fetches lead trend rows and all organizations into memory, which can become expensive at platform scale.
- Hardcoded chart colors and green backgrounds may not fully match dark/light theme tokens.

Possible root cause:

- The dashboard mixes lifetime platform metrics and live operational metrics without an explicit metric contract.
- Aggregations are implemented partly in application memory for speed of development.

Best-practice solution:

- Define a dashboard metrics contract:
 - Active organizations
 - Suspended organizations
 - Archived organizations
 - Live users
 - Live leads
 - Approved quotation value
 - Subscription MRR/ARR when gateway data exists
- Rename "Total Revenue" to "Approved quotation value" unless it truly means billing revenue.
- Add archived handling explicitly to dashboard repository queries.
- Add an "Other" bucket for lead distribution.
- Use theme tokens for chart colors.

Performance improvements:

- Push monthly/weekly bucketing to the database or use materialized platform metrics.
- Add DB-side top N aggregation for organization lead distribution.
- Cache Super Admin dashboard stats for 1 to 5 minutes.
- Avoid loading every organization for distribution when only top N is displayed.

Edge cases to test:

- No organizations exist.
- Only archived organizations exist.

- Suspended organization has many leads/users.
- Organization deleted/archived after dashboard cache.
- Large platform: 10k organizations, 1M leads.
- Timezone boundary around month/week start.
- Approved quotation with zero or null totals.

Testing checklist:

- Verify dashboard totals match chosen KPI definition.
- Verify active/suspended/archived counts match Organizations list filters.
- Verify Super Admin dashboard endpoint rejects non-Super Admin roles.
- Verify mobile dashboard scroll and chart readability.
- Verify dark/light chart contrast.
- Verify dashboard remains responsive with large fixture data.

2. NOTIFICATIONS

Severity: Low to Medium

Affected functionality:

- Notification feed
- Announcement and notification merge
- Unread count
- Mark all read
- Bell/sidebar badge

Bugs/issues found:

- Per-user notification reads are correctly scoped by user id.
- "Mark all read" for normal notifications only processes one bounded batch of 200, so users with more unread notifications may still have unread items after clicking.
- Notifications page uses 'announcementsLoading && notificationsLoading', so if only one source is loading the page may show partial data without a visible loading/refresh state.
- Feed limit is finite; long notification history is not paginated in the full notifications page.

Possible root cause:

- Notification repository intentionally bounds hot-path writes but does not loop batches like announcement receipts do.
- The full notifications page reuses the bell feed pattern instead of a true history list.

Best-practice solution:

- Loop unread notification batches until zero, with a max-batch guard.
- Add pagination or infinite scroll for the notifications page.
- Use separate partial loading indicators for announcements and direct notifications.
- Keep per-user scoping in the repository.

Performance improvements:

- Keep unread count indexed by '[userId, readAt]'.
- Consider archival/retention for old notification rows.
- Avoid polling full read history every minute; poll unread count separately and fetch history on demand.

Edge cases to test:

- Super Admin has zero notifications.
- Super Admin has more than 200 unread notifications.
- Announcement unread count and notification unread count disagree during simultaneous mark-all.
- Delete notification while feed refetch is in progress.
- Dismiss announcement then view full history.

Testing checklist:

- Verify one user cannot mark another user's notification read or delete it.
- Verify mark-all clears all unread items, not only first batch.
- Verify badge count equals visible unread count.
- Verify bell and full page show consistent ordering.
- Verify mobile notification cards do not overflow.

- Verify polling does not spam errors after token expiry.

3. ORGANIZATIONS

Severity: High

Affected functionality:

- Organization list
- Add/edit organization
- Organization workspace
- Suspend/archive/restore
- Tenant context for nested Super Admin modules

Bugs/issues found:

- 'OrganizationDetail' sets 'selectedOrganizationId' but does not clear it when leaving the page.
- API interceptor sends 'x-organization-id' for all Super Admin requests when selected org id exists.
- 'GET /organizations/by-slug/:slug' is public and returns id, slug, prefix, logo, and status.
- Public slug endpoint is currently used for Super Admin workspace/detail resolution, not a public login requirement.
- Uploading organization assets before body validation can leave orphan files if validation fails.
- Replacing organization assets does not appear to delete old asset files.
- Organization list handles archived filtering carefully, but dashboard metrics may not match its default live-only behavior.

Possible root cause:

- Tenant context is stored globally in Redux rather than route-locally.
- Slug lookup was made public as a convenience for client-side route resolution.
- Multer disk storage writes files before controller validation and DB transaction.

Best-practice solution:

- Add cleanup to every route that sets selected organization context, or better centralize it in a scoped provider.
- Only inject 'x-organization-id' for tenant endpoint groups.
- Require authentication and Super Admin/tenant membership for slug lookup.
- Consider resolving organization workspace by slug through an authenticated Super Admin endpoint.
- Use temp upload directories and promote files after validation and DB success.
- Delete old assets after replacement or run orphan cleanup.

Performance improvements:

- Organization list already paginates and caps limit at 100.
- For platform-scale search, consider trigram/full-text indexes on name/slug/prefix.
- Avoid duplicate organization detail calls by letting slug endpoint return full authorized detail or by changing workspace route to id.

Edge cases to test:

- Navigate from '/super-admin/organizations/:slug/edit' to '/super-admin/billing' and ensure no stale tenant context remains.
- Archived organization slug lookup.
- Duplicate slug/prefix against archived organization.
- Suspend active organization with logged-in tenant users.
- Restore archived organization and verify subscription/billing state.
- Upload invalid file type, oversized file, and invalid body plus valid file.
- Long organization names on mobile.

Testing checklist:

- Verify Super Admin can list, search, filter active/suspended/archived organizations.
- Verify suspend blocks tenant login/refresh/API access immediately.
- Verify archive forces suspended and hides from default list.
- Verify restore reactivates and audit row is written.
- Verify public unauthenticated slug lookup is removed or minimized.

- Verify selected organization id is cleared after leaving scoped pages.
- Verify organization asset replacement and cleanup behavior.

4. BILLING

Severity: Medium

Affected functionality:

- Super Admin billing console
- Plan create/edit
- Subscription edit
- Feature overrides
- Organization workspace billing
- Subscription banner

Bugs/issues found:

- Plan form fields are technically correct but need operator clarity:
 - 'code' is the stable machine key used by code, seeds, scripts, and audit.
 - 'slug' is the URL-friendly unique identifier for pricing pages/deep links.
 - 'Assignable' off means the plan is retired and cannot be newly assigned; existing subscribers are unaffected.
 - 'Offered to customers' off means the plan stays assignable by Super Admin but is hidden from customer/self-serve menus.
- Subscription status filtering resolves effective status in memory after fetching all matching subscriptions.
- Subscription banner links Super Admin to '/settings', which is tenant settings oriented, not the Super Admin billing console or org workspace billing.
- Super Admin Settings page can show "No organization selected" when accessed globally.
- Retired plan changes are logged but should have stronger UI warnings when subscribers are affected.
- Manual/offline billing fields are practical but there is no invoice/payment history yet.

Possible root cause:

- Billing has both tenant and platform surfaces, but navigation and Settings still blur the distinction.
- Effective status depends on current time and dates, so it is not a simple DB column filter.

Best-practice solution:

- Keep plan slug, code, isActive, and isPublic as separate concepts.
- Add help text/tooltips in the plan form explaining the four fields in plain language.
- For Super Admin banner CTA, route to '/super-admin/billing' or '/super-admin/organizations/:slug/billing'.
- Split tenant settings from platform settings.
- Add a confirmation dialog when retiring a plan or lowering enforced limits while subscribers are on it.
- For effective status filters, add materialized status, scheduled resolver, or DB where approximations.

Performance improvements:

- Avoid fetching all subscriptions for status filters on large installations.
- Add indexes for subscription search fields and organization name joins if the billing list grows.
- Cache plan catalogue queries.
- Use background jobs for billing status snapshots.

Edge cases to test:

- Retire plan with active subscribers.
- Hide plan from customer menu but keep assignable.
- Assign retired plan to a subscription: should fail unless current plan is already retired and unchanged.
- Expired ACTIVE subscription shows effective EXPIRED.
- Trial with no trial end date.
- Cancel at period end before and after current period end.
- Organization with missing subscription repair flow.

- Lower seat limit below current usage.

Testing checklist:

- Verify Super Admin can create/edit plans and subscriptions only through protected routes.
- Verify non-Super Admin cannot manage plans.
- Verify plan slug uniqueness and validation.
- Verify 'isActive=false' prevents new assignment.
- Verify 'isPublic=false' hides only public/customer menu surfaces.
- Verify effective status filters return correct totals and pagination.
- Verify billing changes are audited.
- Verify billing UI is responsive and dark/light consistent.

5. ANNOUNCEMENTS

Severity: Medium

Affected functionality:

- Announcement list
- Create/edit/publish/archive/delete
- Target organizations
- Target roles
- Bell/banner visibility
- Read/dismiss receipts

Bugs/issues found:

- Backend correctly locks audience changes for both PUBLISHED and SCHEDULED announcements.
- UI locks audience only when status is PUBLISHED, so scheduled announcements appear editable but save can fail.
- Super Admin can only author PLATFORM announcements; this is enforced and intentional.
- Announcement table resolves organization names by fetching only first 100 organizations. Target ids outside that page may display poorly or be omitted.
- Full management list can filter by organization id, but the filter UI currently does not expose an organization picker.
- Feed visibility for Super Admin intentionally does not show every platform announcement; management list is the platform view. This should be documented in help.

Possible root cause:

- UI status logic drifted from backend business rules.
- Organization name resolution is done client-side with a paged list rather than included in the announcement DTO.

Best-practice solution:

- Update UI lock condition to PUBLISHED or SCHEDULED.
- Include target organization names/counts in announcement list DTO.
- Add organization filter/search picker to Super Admin announcement management.
- Document that Super Admin authors platform announcements and reads/manages them in the management list.

Performance improvements:

- Avoid fetching organization list just to map target ids.
- Index announcement filters already exist; add tests for query combinations.
- For large platforms, avoid array-field scans on 'targetOrganizationIds' if targeting becomes heavy; consider a join table.

Edge cases to test:

- Publish immediate vs scheduled announcement.
- Scheduled announcement crosses publishAt without a status-flipping job.
- Expired announcement should disappear from feed.
- Target all organizations vs selected organizations.
- Target selected roles.
- Dismissible false should keep banner/feed visible.
- Archive live announcement and verify it disappears.
- Delete soft-deletes and keeps receipts.

Testing checklist:

- Verify Super Admin can create platform draft.
- Verify Admin cannot create platform announcement.
- Verify audience cannot change after publish or schedule.
- Verify target org visibility across two organizations.
- Verify role targeting for Admin, Manager, Executive.
- Verify unread counts and receipts.
- Verify mobile announcement table cards.

6. AUDIT LOG

Severity: Medium

Affected functionality:

- Audit log list
- Filters
- Detail diff dialog
- Platform vs organization activity visibility
- Compliance trail

Bugs/issues found:

- Audit repository is append-only at code level and scrubs sensitive keys.
- Super Admin can read all logs; organization admins are pinned to their org and cannot see platform-only activity.
- Completeness depends on each controller remembering to call 'recordAudit'.
- Profile update audit records only 'Object.keys(data)' and may omit file-only asset uploads.
- There is no export, retention policy, tamper-evidence, or immutable storage strategy.
- Filter UI lacks direct actor id/entity id/organization picker fields even though backend supports some of these query params.

Possible root cause:

- Audit is implemented as explicit controller calls rather than a required domain-event wrapper.
- Compliance features are still minimal.

Best-practice solution:

- Create an audit coverage matrix for every mutating endpoint.
- Include uploaded file field names in profile/asset audit rows, without storing file paths or sensitive content.
- Add export to CSV/PDF for Super Admin.
- Add organization, actor, entity id, and date range filters in UI.
- Consider immutable append-only storage, hash chaining, or WORM storage if compliance matters.

Performance improvements:

- Current indexes are good for common filters.
- For high-volume audit, partition by month or archive older logs.
- Add cursor pagination for deep history.

Edge cases to test:

- Failed permission and subscription events are audited by global error handler if configured.
- Login failed for known vs unknown email.
- Super Admin action on tenant resource has organizationId attached.
- Profile asset-only update.
- Search and filters combined with pagination.
- Date range timezone boundaries.

Testing checklist:

- Verify every Super Admin create/update/delete/publish/archive/reset action writes audit.
- Verify audit snapshots exclude passwords/tokens/secrets.
- Verify org admin cannot see Super Admin platform rows.
- Verify Super Admin can filter by action/entity/date/search.
- Verify diff dialog handles null before/after.
- Verify audit table mobile cards show useful context.

7. PROFILE

Severity: Medium

Affected functionality:

- Profile image upload
- Personal details update
- Password change
- Theme toggle
- Quotation PDF assets

Bugs/issues found:

- Profile image upload validates type/size on both client and server.
- Super Admin can change password; Manager/Executive password panel is hidden.
- Organization assets are only shown for Admin/Manager, so Super Admin profile does not show tenant PDF assets globally.
- Upload middleware writes files before request validation, so invalid body plus valid file can leave orphan files.
- Asset-only profile updates may not be fully reflected in audit 'fields'.
- Public '/uploads' means profile images and organization assets are accessible by URL.
- Async profile image dispatch does not unwrap/rethrow errors, so local upload spinner clears but failure handling relies on slice/toast behavior.

Possible root cause:

- Disk upload middleware precedes validation in Express route order.
- Audit row intentionally stores only touched field names but file fields are not added to that list.

Best-practice solution:

- Use temp uploads and cleanup on validation or DB failure.
- Add uploaded field names to audit after fields.
- Consider signed/private asset delivery for sensitive images.
- Use mutation unwrap or explicit result checks for image upload actions.
- Add image metadata stripping and malware scanning if assets are customer-provided in production.

Performance improvements:

- Compress/resize profile images and logos server-side.
- Store assets in object storage/CDN rather than local disk for production.
- Cache resolved asset URLs.

Edge cases to test:

- Invalid image type.
- File larger than 5MB.
- Valid file plus invalid first/last name.
- Network error during upload.
- Password changed should invalidate old sessions.
- Theme toggle persists after refresh.
- Mobile profile layout with long email/name.

Testing checklist:

- Verify Super Admin can update name/mobile/profile image.
- Verify password change logs out or invalidates refresh token as intended.
- Verify upload failures show clear toast and do not update UI incorrectly.
- Verify no orphan files after validation failures once fixed.
- Verify profile page dark/light consistency.
- Verify public asset exposure is acceptable or replaced with protected access.

8. SETTINGS

Severity: Medium

Affected functionality:

- Settings page
- Billing tab
- Subscription banner CTA
- Platform vs tenant configuration

Bugs/issues found:

- Settings page copy says "Manage your organization's plan and preferences" even for Super Admin.
- The only settings tab is Billing, which is tenant-oriented.
- For global Super Admin access, BillingView can show "No organization selected".
- Super Admin already has '/super-admin/billing', so Settings duplicates or misroutes billing work.
- There is no visible platform settings surface for security, branding, defaults, support, feature policy, or system preferences.

Possible root cause:

- Settings was built as organization admin settings and later allowed for Super Admin without a separate platform settings design.

Best-practice solution:

- Split settings into:
 - Tenant settings: organization plan/preferences for Admin.
 - Platform settings: Super Admin system preferences.
- Hide Settings for Super Admin until a real platform settings page exists, or route it to platform settings.
- Update subscription banner CTA by role and scope.

Performance improvements:

- Minimal performance concern today.
- Avoid firing tenant billing queries when no organization is selected.

Edge cases to test:

- Super Admin opens '/settings' from sidebar.
- Super Admin opens Settings after visiting an organization workspace.
- Super Admin opens Settings with stale selected organization from edit page.
- Admin opens tenant settings with lapsed subscription.
- Direct URL access by Manager/Executive should be denied.

Testing checklist:

- Verify Settings route roles match intended product behavior.
- Verify global Super Admin settings never show stale tenant billing.
- Verify Admin settings stays organization-scoped.
- Verify loading and empty state wording is role-aware.
- Verify mobile settings tabs and billing content.

9. HELP

Severity: Low to Medium

Affected functionality:

- Help page
- FAQs
- Search
- Action cards
- Support contacts

Bugs/issues found:

- Super Admin FAQ content is thin and partly stale:
 - It says "Create Organization" while UI uses "+ Add Organization".
 - It says admin can be assigned from Users tab, but initial admin is created during organization creation.
- Help action cards look clickable but do not navigate or open mail/ticket flows.
- Filter button has no behavior.
- Support email and phone are placeholders.
- Search only matches questions, not answers or module names.

- No Super Admin help for billing, plan slug/code, isActive/isPublic, subscription status, announcements, audit logs, suspension/archive, or organization workspace.

Possible root cause:

- Help was implemented as static starter content, not as maintained product documentation.

Best-practice solution:

- Create role-specific help content from actual routes and labels.
- Make action cards real links/actions.
- Remove dead filter button or implement category filters.
- Add searchable help topics for Super Admin workflows.
- Move support contacts to configuration/env.

Performance improvements:

- Static help is lightweight.
- If help becomes large, index locally or fetch docs by role.

Edge cases to test:

- Search no results.
- Long FAQ answer on mobile.
- Keyboard accessibility of FAQ toggles.
- Action card click behavior.
- Dark/light styling.
- Placeholder support values in production.

Testing checklist:

- Verify Super Admin help content matches real screens.
- Verify "plan slug", "assignable", and "offered to customers" are explained.
- Verify search covers question and answer text.
- Verify action cards navigate or open correct support flow.
- Verify no dead buttons remain.
- Verify mobile layout and dark/light consistency.

IMPROVEMENT ROADMAP

Phase 0: Baseline and Safety Net

Goal: Lock down expected behavior before fixes.

Actions:

- Create Super Admin test users and at least three organizations: active, suspended, archived.
- Create billing fixtures: active plan, retired plan, private plan, expired subscription, cancelled subscription, org without subscription.
- Add e2e smoke tests for Super Admin navigation and tenant scoping.
- Add API tests for direct-route calls, not only browser flows.

Phase 1: Data Isolation and Security

Goal: Remove cross-organization leakage risks.

Actions:

- Fix stale selected organization cleanup in organization detail/edit routes.
- Add backend requirement that Super Admin must provide org scope for tenant-data modules.
- Restrict 'x-organization-id' injection to tenant endpoints.
- Protect or minimize organization slug lookup.
- Add tests that direct API calls without scope fail for tenant data routes.

Phase 2: Correctness and Operator Clarity

Goal: Make Super Admin decisions predictable.

Actions:

- Define dashboard KPI semantics and update labels/queries.
- Fix subscription banner CTA for Super Admin.
- Split Super Admin platform settings from Admin tenant settings.
- Lock scheduled announcement audience in UI.
- Add plan form help text for code, slug, assignable, and offered-to-customers.

Phase 3: Performance and Operational Hygiene

Goal: Keep the platform stable as data grows.

Actions:

- Move dashboard trend/distribution aggregation into DB-side queries or materialized stats.
- Replace in-memory subscription effective-status filtering with materialized state or DB filters.
- Batch-loop notification mark-all-read.
- Add upload temp/promotion cleanup and old asset deletion.
- Add audit export and retention policy.

Phase 4: UX, Responsive, and Dark/Light Polish

Goal: Make the Super Admin console feel production-ready.

Actions:

- Replace hardcoded colors with theme tokens.
- Review all Super Admin tables/cards on mobile.
- Add robust empty, loading, and partial-loading states.
- Improve Help content and make action cards functional.
- Add organization picker filters where backend already supports organization filtering.

MODULE-WISE TESTING CHECKLIST

Dashboard

- Super Admin can access '/dashboard'; Admin/Manager/Executive cannot access '/api/v1/dashboard/super-admin'.
- KPI totals match the selected metric definition.
- Archived organizations are either excluded or separately counted.
- Suspended organization data is clearly included/excluded.
- Lead trend handles empty data and timezone boundaries.
- Dashboard charts remain readable in dark and light mode.
- Mobile layout has no horizontal content overlap except intended table scroll.
- Large fixture data does not time out.

Notifications

- Feed shows both direct notifications and announcements in correct order.
- Unread badge equals notification unread plus announcement unread.
- Mark one read updates UI and server state.
- Mark all read clears more than 200 unread notifications.
- Delete only removes caller's own notification.
- Dismissed announcements appear in full history when requested.
- Loading state is clear when only one feed source is loading.
- Mobile cards do not overflow with long title/body.

Organizations

- Create organization also creates admin user, sequences, and subscription atomically.
- Duplicate slug/prefix rejects even when duplicate belongs to archived organization.
- Public slug endpoint is protected or minimized.

- Suspend blocks tenant users immediately.
- Archive hides organization from default list and reserves slug/prefix.
- Restore returns organization to expected active behavior.
- Stale selected organization is cleared after leaving detail/edit/workspace routes.
- Organization asset uploads validate type/size and clean up failed uploads.

Billing

- Super Admin can create plan with valid code/slug/features.
- Duplicate plan code/slug rejects.
- Retired plan cannot be newly assigned.
- Private plan is hidden from customer menu but assignable by Super Admin.
- Existing subscribers remain on retired plans.
- Expired/cancelled/past-due effective statuses resolve correctly.
- Status filter pagination returns correct totals.
- Feature override save/revert works.
- Billing changes appear in audit log.
- Super Admin billing CTA opens the correct platform or organization billing page.

Announcements

- Super Admin can create platform draft.
- Admin cannot create platform announcement.
- Publishing immediate announcement makes it visible immediately.
- Scheduled announcement becomes visible after publishAt.
- Published and scheduled audiences cannot be changed in UI or API.
- Target organization selection reaches only selected organizations.
- Target role selection reaches only selected roles.
- Expired or archived announcements disappear from feed.
- Read/dismiss receipts update unread counts.
- Announcement list target organization names work beyond first 100 organizations.

Audit Log

- Super Admin can view platform and organization logs.
- Admin can view only own organization logs.
- Platform-only actions are hidden from Admin.
- Every Super Admin mutation writes an audit row.
- Passwords, tokens, secrets, and generated temporary password never appear in audit.
- Profile asset-only update records touched file fields.
- Filters combine correctly with pagination.
- Detail diff handles null before/after.
- Export, retention, and immutable storage requirements are defined.

Profile

- Super Admin can update first name, last name, mobile, and profile image.
- Invalid/oversized profile image is rejected client and server side.
- Failed profile upload does not leave stale preview or orphan file after cleanup fix.
- Password change invalidates older sessions.
- Theme toggle persists and applies globally.
- Public uploaded asset URLs are accepted by policy or replaced.
- Mobile layout handles long name/email.
- Dark/light mode styling is consistent.

Settings

- Super Admin '/settings' behavior is defined: platform settings or hidden.
- Admin settings remains organization-scoped.
- Manager/Executive cannot access settings.
- Billing tab does not query without required organization context.

- Subscription banner routes Admin and Super Admin to correct billing surfaces.
- Empty/loading/error states are role-aware.
- Dark/light and mobile layouts are consistent.

Help

- Super Admin FAQs match real route labels and flows.
- Plan slug/code/isActive/isPublic are explained.
- Search covers questions, answers, and module keywords.
- Filter button either works or is removed.
- User Guide, Contact Administrator, and Submit Ticket cards perform actions.
- Support contacts are real/configurable.
- FAQ interactions are keyboard-accessible.
- Help page works on mobile and dark/light modes.

RECOMMENDED FIX ORDER

1. Fix stale selected organization context and backend tenant-scope enforcement.
2. Protect or minimize public organization slug lookup.
3. Clarify dashboard KPI definitions and update dashboard queries/labels.
4. Split Super Admin Settings from tenant Billing settings.
5. Align announcement UI with backend scheduled/published audience locking.
6. Add upload cleanup and file lifecycle management.
7. Improve billing status filter scalability.
8. Improve notification mark-all-read batching.
9. Expand audit coverage/export and Help content.
10. Complete dark/light, responsiveness, and empty/loading state polish.

FINAL NOTES

The Super Admin design is close to a sound platform console, but it needs a clearer boundary between platform mode and tenant-scoped mode. Once that boundary is explicit in both routing and backend middleware, most of the remaining issues become manageable correctness, UX, and scale improvements rather than serious data-isolation risks.